Hardening a Compromised Windows 11 Laptop: An Assume-Breach Security Stack

TL;DR

- **Trust the network, not the host.** Because the laptop's own admin account is presumed controlled by an attacker, the single highest-value move is to build an **out-of-band network sensor** (a separate Intel N100 mini-PC running Suricata + Zeek + Arkime, ideally as Security Onion) fed by **hardware port mirroring from your Xiaomi AX3000T** — the MT7531 switch supports ASIC-offloaded SPAN via `tc`/`mirred`, so the attacker on the laptop cannot see or tamper with this monitoring. On-host tools (Sysmon, GlassWire, Autoruns, Malwarebytes) are still worth running for evidence but must be treated as potentially blinded or fed false data.
- **Right now (compromised state):** do detection and evidence-gathering only — stand up the network sensor, capture full packet traffic, enable Sysmon + Windows Firewall auditing, run Autoruns/TCPView for a persistence baseline, and scan from **trusted bootable rescue media** (Kaspersky Rescue Disk / ESET SysRescue / Microsoft Defender Offline) rather than the running OS. Do NOT trust any "all clear" from a tool running inside the compromised Windows.
- **Best cost-benefit:** the whole high-value stack is mostly free/open-source (~$150–300 one-time for the mini-PC + USB NICs). The one paid subscription genuinely worth it for an individual is **Huntress Managed EDR** (~$8.99/endpoint/month ≈ $107.88/yr at the 50–99 unit tier) on the clean rebuild for a managed human SOC; everything else (Suricata, Zeek, Sysmon, oletools, CAPA, YARA, VirusTotal free API, MCP servers) is free.

Key Findings

The threat model dictates the architecture

With an attacker holding admin (and possibly kernel) control, anything running *on* the laptop is inside the attacker's trust boundary. An on-host agent can be killed, its logs forged, its driver unhooked, or its alerts suppressed. The widely used SwiftOnSecurity Sysmon configuration states the principle bluntly in its own file: *"Sysmon is not hardened against an attacker with admin rights. Additionally, this configuration offers an attacker, willing to study it, limited ways to evade some of the logging."* Therefore the architecture must put the authoritative detection layer **off the host**: on the router, on a separate sensor device, and on bootable media that runs *instead of* the compromised OS. On-host tooling is demoted to (a) evidence collection while you still have the compromised image, and (b) defense-in-depth on the clean rebuild.

Out-of-band network monitoring is the centerpiece — and your router can feed it

The Xiaomi AX3000T (MediaTek MT7981B / Filogic 820, MT7531AE switch) on OpenWrt 23.05+ uses DSA. The old swconfig `mirror_*` UCI knobs are gone (confirmed in OpenWrt forum thread "Did DSA remove switch port-mirroring?": *"mirroring is no longer inside switch*

configuration. You need to use tc mirred module..."), but the `mt7530` DSA driver implements **hardware port-mirroring offload** for the MT7531 (driver `mt7530.c` covers MT7530/MT7531/MT7988 and implements `mt7530_port_mirror_add/del`). You configure it at runtime with `tc`:

```sh
opkg install tc-full ip-full
ip link set up dev lan4
tc qdisc add dev wan clsact
tc filter add dev wan ingress matchall skip_sw action mirred egress mirror dev lan
tc filter add dev wan egress  matchall skip_sw action mirred egress mirror dev lan
```

`skip_sw` forces ASIC offload (near-zero CPU cost, line rate). The hardware allows **one monitor port**; remove it from `br-lan` so it's a dedicated SPAN port, and persist the commands in an init script (they don't survive reboot). This exact `tc` recipe is confirmed working on MT7530/MT7531-class devices feeding Security Onion (forum "Port mirroring for IDS": *"I can confirm the SO is now getting all the packets forwarded to it"*) and Suricata. The attacker on the laptop has no visibility into or control over this mirror.

On-host network/port/firewall tools: useful but inside the trust boundary

TCPView, Process Explorer, Process Monitor and Autoruns (the Sysinternals suite) are the right free tools for inspecting outbound connections, listening ports, and persistence — and Process Explorer and Autoruns have **built-in VirusTotal lookups**. GlassWire and Portmaster give continuous outbound-connection visualization and per-app blocking. But every one of these depends on a kernel the attacker may own; a rootkit can hide a process from Process Explorer or a connection from TCPView. Use them, but corroborate against the out-of-band sensor.

File/macro/document analysis has excellent free tooling with Python APIs

For the developer who wants scriptable tools: **oletools** (olevba/oledump/oleid/mraptor) for Office macros, **pdfid**/**pdf-parser** for PDFs, **CAPA** (Mandiant) for capability detection, **YARA** for signatures, **Detect It Easy (DIE)** and **pestudio** for PE triage — all free, most with Python interfaces. For detonation, **VirusTotal** (free API), **Any.Run** (free community tier), **Hybrid Analysis**, **Joe Sandbox Cloud Basic**, and self-hosted **CAPE** cover both cloud and local sandboxing. Medium

MCP servers turn Claude into a security analyst — a strong fit for this user

Multiple maintained MCP servers expose threat-intel and analysis tools to Claude/Claude Code: a VirusTotal MCP, Shodan MCP, unified threat-intel MCPs (OTX/AbuseIPDB/GreyNoise/abuse.ch), and the comprehensive **CVE MCP Server** (27 tools across 21 APIs). These are directly usable by a developer learning Python/AI engineering.

Details

Layer 1 — Out-of-band network sensor (highest priority)

Hardware. Buy a fanless **Intel N100 mini-PC with 16 GB RAM and an NVMe SSD** (commonly ~$150; note the N100 uses single-channel memory, so one fast DDR5 stick is typical). The N100 has AES-NI and roughly 1.5–2× the CPU of a Raspberry Pi 5 with far better x86 software support, native NVMe, and the option of multiple 2.5GbE NICs — markedly better for Suricata/Zeek/full-packet-capture than a Pi. A Raspberry Pi 5 (8–16 GB) is a viable cheaper alternative for Suricata + Zeek at home-internet speeds but struggles with heavy full-packet capture and lacks native fast storage. Security Onion's own project notes the Pi is "simply not powerful enough" for the full stack — so on a Pi, run standalone Suricata+Zeek, not Security Onion.

Software options (all free/open-source):

- **Security Onion** — the recommended turnkey platform: bundles Suricata (signature IDS), your choice of Zeek or Suricata for protocol metadata, Strelka for file analysis, full packet capture, Elastic stack, and a hunting/case UI. Needs x86 and real RAM — run it on the N100, not a Pi. Per the project, it "has been downloaded over 2 million times and is being used by security teams around the world."
- **Suricata** — signature-based IDS/IPS, multi-threaded, maps alerts to MITRE ATT&CK; best at catching known C2/exploit traffic, including T1071 (app-layer C2) and T1567 (exfiltration to cloud).
- **Zeek** — behavioral/protocol logging ("forensic investigator with a photographic memory"); turns traffic into rich connection/DNS/TLS/HTTP/SMB logs ideal for spotting beaconing and exfiltration patterns signatures miss.
- **ntopng** — live L7 traffic visualization; ingests Suricata alerts; Community edition is GPLv3. Good real-time "who is my laptop talking to" dashboard.
- **Arkime** — open-source full-packet-capture + indexed search (created to replace commercial FPC at AOL); pair with Suricata for alert enrichment. Storage-hungry — budget disk.
- **Malcolm** — containerized Zeek+Arkime+Suricata+OpenSearch+YARA/ClamAV+MISP bundle; deploys via Docker from Pi to cloud. (Zeek)

How it detects the user's wants: outbound C2/beaconing/exfiltration (Suricata sigs + Zeek connection analytics + ntopng flows), incoming connections (same), and it does so from a device the laptop attacker cannot tamper with. This is the authoritative answer to "real-time monitoring of outgoing/incoming packets."

Python/automation: Suricata emits EVE JSON; Zeek logs are tab/JSON and Zeek has a scripting language; Arkime and ntopng expose REST APIs — all scriptable by a Python developer.

Layer 2 — On-host telemetry (evidence + defense-in-depth, not authoritative)

- **Sysmon** + **SwiftOnSecurity config** (or **olafhartong/sysmon-modular** for MITRE ATT&CK coverage). Sysmon Event ID 1 (process creation w/ full command line + parent +

hashes), ID 3 (network connections — catches C2 callbacks), ID 22 (DNS). Windows 11 now ships a built-in Sysmon (disabled by default). **Trust caveat:** an admin attacker can tamper with Sysmon; mitigate by **forwarding events off-box immediately** via Windows Event Forwarding (WEF) to a collector (the N100), so logs land somewhere the attacker can't retroactively edit. Velociraptor can also forward Sysmon via ETW.

- **Wazuh** — free open-source SIEM/XDR with agents on Windows; file integrity monitoring, registry monitoring, rootcheck, VirusTotal hash enrichment, MITRE ATT&CK mapping. Server runs on the N100/Linux. Freemium (open core is genuinely free). (Medium) (Packet Labs)
- **Velociraptor** — free DFIR/threat-hunting platform using VQL to interrogate endpoints for processes, persistence, PowerShell activity, memory artifacts. Best for "hunt for what and why" after an alert. Pairs with Wazuh (Wazuh alerts → Velociraptor hunts). (SoftStrix)
- **OSSEC** — older HIDS with log analysis, FIM, registry monitoring, rootkit detection. (GitHub)
- **Trust caveat for all:** these are on-host agents; on a kernel-compromised box they can be subverted. Their value is (a) feeding a remote collector and (b) running on the clean rebuild.

Commercial EDR for an individual — honest take:

- **Huntress Managed EDR** — the standout for a prosumer: **$8.99/endpoint/month at the 50–99 unit tier (≈ $107.88/yr)**, includes a 24/7 human SOC; Huntress's official Managed EDR page advertises *"an industry-leading 8 minute MTTR"* and a sub-1% false-positive rate (vendor/user-validated, not independently audited), and it is explicitly designed to layer on top of Microsoft Defender AV. The catch: a **50-agent minimum commitment**; per Huntress 2026 pricing, organizations under 50 "typically purchase through an MSP partner, which aggregates volume." If you can access it via an MSP, the managed SOC is the best per-dollar protection on the clean rebuild.
- **CrowdStrike Falcon Go** — confirmed on CrowdStrike's pricing page at **$59.99/device/year**, with purchases "limited to a maximum of 100 devices"; small-business NGAV tier that lacks the full EDR/XDR of higher tiers (Falcon Pro $99.99/device/yr; Falcon Enterprise, the first tier with Insight XDR/EDR, $184.99/device/yr).
- **SentinelOne** — from ~$69.99–79.99/endpoint/yr (Control), strong autonomous on-device AI and ransomware rollback, but really needs someone to watch it.
- **Microsoft Defender for Business** — included in Microsoft 365 Business Premium or available standalone; up to 300 users, **no minimum device requirement**, EDR + ASR + auto-investigation, exposes Defender APIs. Best fit if you already use Microsoft 365. Note **Defender for Endpoint Plan 2** is enterprise/standalone and is also included in M365 E5.
- **Two kernel-level EDRs will conflict** — don't stack CrowdStrike + SentinelOne + Defender for Endpoint as peers; the supported exception is Huntress layered on Defender AV.

Layer 3 — Outbound/port/firewall monitoring on Windows

- **Portmaster** (Safing) — free, open-source application firewall; per-app and global rules, secure DNS, ad/malware filter lists, monitors all connections. Open-source = auditable, the better pick under an assume-breach mindset. Note: like all WFP-based tools, if Windows Firewall is disabled it can be blinded.
- **GlassWire** — polished network visualization + alerts on new connections/ARP spoofing/system-file changes; freemium (free tier limits blocking). The user **already owns this** — keep it for its at-a-glance graphs, but understand it's closed-source and uses WFP in user-space.
- **TinyWall** — free, open-source, ~2 MB, default-deny outbound, no nag popups; great lightweight hardening of Windows Firewall.
- **Sysinternals**: **TCPView** (live sockets/ports + remote IPs), **Process Explorer** (process tree + VirusTotal column), **Process Monitor** (file/registry/process activity), **Autoruns** (every autostart location — the primary persistence-hunting tool, with VirusTotal integration and a PowerShell `Compare-AutoRunsBaseLine` workflow to diff against a known-good baseline).
- **Detecting firewall tampering:** enable auditing and watch Windows Security Event IDs **4946** (rule added), **4947** (rule modified), **4948** (rule deleted), **4950** (setting changed), and **5025** (firewall service stopped). Windows 10/11 do **not** log these by default — turn on the "Policy Change → MPSSVC Rule-Level Policy Change" audit subcategory. Forward these to the N100 collector so tampering is recorded off-box. `Lansweeper`

Layer 4 — File / macro / document analysis (scriptable)

Static (free, local):

- **oletools** — `olevba` (extract/analyze VBA macros), `oledump`, `oleid`, `mraptor` (detect malicious macros), `rtfobj`, `pyxswf`. Pure Python (`pip install oletools[full]`), so directly importable in your own scripts. `GitHub`
- **PDF**: Didier Stevens' `pdfid` and `pdf-parser` (Python).
- **CAPA** (Mandiant) — identifies program capabilities from a PE via signatures over imports/strings/etc.; CLI + Python.
- **YARA / YARA-X** — pattern-matching engine; YARA-X is the faster Rust rewrite. Python bindings.
- **Detect It Easy (DIE)** and **pestudio** — packer/compiler ID and PE triage (pestudio flags suspicious imports against blacklists).
- **FLOSS** (Mandiant) — deobfuscates/extracts hidden strings.

Dynamic / detonation:

- **VirusTotal** — 70+ engines; per VirusTotal's docs the Public API "is limited to 500 requests per day and a rate of 4 requests per minute" and "must not be used in commercial

products or services." Official `vt-py` Python client (async) and `virustotal-python`. Use it to check hashes before opening files and to enrich Autoruns/Process Explorer findings.

- **Any.Run** — interactive cloud sandbox; free Community tier (public submissions, Win7 32-bit on free) good for triaging phishing/malware behavior in real time. Paid tiers add private analysis and modern Windows. G2
- **Hybrid Analysis** (CrowdStrike Falcon Sandbox) — free community with a vetting process for API/sample access. Slashdot
- **Joe Sandbox Cloud Basic** — free tier; deep static+dynamic; REST API on paid plans. Zeltser
- **CAPE** — open-source successor to Cuckoo; auto-extracts payloads/configs; self-host on the N100 or a separate VM. SOCRadar
- **Build a local detonation VM:** an isolated VM (host-only/no network or routed through the sensor), snapshot before/revert after; consider **FLARE-VM** (Windows analysis toolkit) and **REMnux** (Linux analysis distro). Always source samples safely and never detonate on the host.

Trust caveat: evaluate suspicious files on a *separate* clean analysis machine/VM, not the compromised laptop — results from a tool on the compromised host can't be trusted.

Layer 5 — Threat intelligence & IOC checking (all expose APIs)

- **VirusTotal** (file/URL/domain/IP; `vt-py`).
- **AbuseIPDB** — IP reputation; free tier for individuals.
- **Shodan** — exposed-service/host intel; Python library.
- **GreyNoise** — distinguishes mass-internet-scan noise from targeted activity; free Community API (limited daily lookups). Their Plasma sensor even runs on a Raspberry Pi.
- **AlienVault OTX** — community IOC feeds.
- **MITRE ATT&CK, CISA KEV, EPSS, OSV.dev** — free, no key.

Layer 6 — MCP servers & AI-assisted analysis (great fit for an AI-engineer-in-training)

Maintained, relevant MCP servers you can plug into Claude/Claude Code:

- **CVE MCP Server** (mukul975) — 27 tools across 21 APIs (NVD, EPSS, CISA KEV, Shodan, VirusTotal, GreyNoise, AbuseIPDB, MalwareBazaar, ThreatFox, MITRE ATT&CK, URLScan, OSV); 8 tools need no API key; weighted risk scoring. Python/FastMCP — readable as a learning codebase.
- **VirusTotal MCP** (BurtTheCoder/mcp-virustotal) — file/URL/domain/IP reports with relationship pivoting.
- **Shodan MCP** (BurtTheCoder/mcp-shodan) — host/IP recon, DNS, CVE/CPE intel. GitHub
- **Unified threat-intel MCP** (mcp-threatintel) — OTX + AbuseIPDB + GreyNoise + abuse.ch; abuse.ch works keyless. GitHub

- **MISP MCP**, **ORKL threat-intel MCP** (fr0gger/MCP_Security), and security-scanner MCPs (e.g., agent-shield for auditing MCP/skills for prompt injection).
- Anthropic's own **threat-intel enrichment agent cookbook** shows the tool-use pattern (swap mock functions for VT/AbuseIPDB/Shodan) — a ready template for your own Python agent.
- **Caution:** point MCP-driven analysis tooling at logs/IOCs from the *trusted sensor*, not from the compromised host, and run the MCP client on a clean machine.

Layer 7 — Persistence / rootkit / compromise assessment from TRUSTED media

This is essential under assume-breach: a rootkit that owns the kernel can hide from any scanner running in the live OS. Scan from a clean environment instead:

- **Microsoft Defender Offline** — boots before Windows, free, built into Windows Security; good first pass for boot-time threats.
- **Kaspersky Rescue Disk** — bootable Linux AV (updated 2026), strong rootkit/bootkit detection, scans boot sectors; UEFI users may need to disable Secure Boot.
- **ESET SysRescue Live** — bootable scanner with disk/memory tools.
- **Others:** Trend Micro Rescue Disk, Comodo Rescue Disk, Dr.Web LiveDisk, Sophos Bootable AV.
- **Autoruns** for a persistence inventory (Run keys, services, scheduled tasks, WMI, Winlogon), ideally diffed against a baseline; **note** even Autoruns runs in the live OS, so confirm against an offline mount.
- **GMER** / **TDSSKiller** exist but are legacy and for experts; prefer offline scans.
- **Verdict:** because firmware/UEFI/bootkits and kernel rootkits may be undetectable and irremovable from the running system, treat scans as *evidence*, not proof of cleanliness. The only reliable remediation is the planned reformat.

Recommendations

Phase 0 — Now, on the compromised setup (detect & preserve only; assume the host lies):

1. **Stand up the N100 sensor** with Security Onion (or standalone Suricata+Zeek if using a Pi). Configure the AX3000T `tc` hardware mirror of the WAN (and/or the laptop's LAN port) to a dedicated SPAN port feeding the sensor. This gives you tamper-proof outbound/inbound/C2/exfil visibility immediately.
2. **Turn on Windows Firewall auditing** (Event IDs 4946–4950, 5025) and **install Sysmon** with the SwiftOnSecurity config; **forward all events via WEF to the N100** so the attacker can't erase them.
3. **Baseline persistence** with Autoruns (export), and snapshot active connections/ports with TCPView and Process Explorer (VirusTotal columns on). Save outputs to external/read-only media.
4. **Scan from trusted bootable media** (Defender Offline → Kaspersky Rescue Disk → ESET SysRescue). Record findings; don't assume "clean" = clean.

5. **Evaluate any suspicious files on a separate machine/VM**, not the laptop, using oletools/CAPA/YARA + VirusTotal/Any.Run.
6. Do **not** authenticate to sensitive accounts from the laptop while compromised (the existing account-remediation workstream covers this).

Phase 1 — Reformat & rebuild (the only real remediation):

1. Back up *data only* (no executables/scripts) after scanning it on the sensor/VM. Destroy and recreate partitions; reinstall Windows 11 from media verified on a clean machine; update firmware/UEFI.
2. On the clean install: enable Defender + ASR rules, BitLocker, Sysmon→WEF→N100, and a host firewall — **Portmaster** (open-source, auditable) as the primary; keep your existing **GlassWire** for visualization or replace with **TinyWall** for default-deny simplicity.
3. **Add managed EDR**: pursue **Huntress** via an MSP (best per-dollar managed SOC, layers on Defender AV). If Huntress is impractical solo, use **Microsoft Defender for Business** (no device minimum) standalone or via M365 Business Premium.
4. Keep the N100 sensor permanent; consider **Wazuh** (server on the N100, agent on the laptop) + **Velociraptor** for ongoing detection-to-hunt.

Phase 2 — Build your scriptable security stack (developer leverage):

1. Get free API keys (VirusTotal, AbuseIPDB, Shodan, GreyNoise) and wire up the **CVE MCP Server** + **VirusTotal/Shodan MCPs** in Claude Code.
2. Write small Python tools with `vt-py`/oletools to auto-triage downloads and enrich Suricata EVE JSON; this doubles as AI-engineering practice.

Thresholds that change the plan:

- If offline scans or the sensor reveal **active C2/exfiltration**, accelerate to Phase 1 immediately and treat all credentials as burned.
- If you find **firmware/UEFI persistence indicators**, a standard reformat is insufficient — reflash firmware or replace the affected hardware, and involve professional IR.
- If you can't reach a **50-agent Huntress** path and don't use M365, default to **Defender for Business standalone** rather than leaving the rebuild on consumer AV alone.

Caveats

- **No on-host tool is trustworthy under assume-breach.** Every Windows-resident tool here (Sysmon, GlassWire, Portmaster, Autoruns, Malwarebytes, even live AV) can be blinded or fed false data by an admin/kernel attacker. Their findings are leads and evidence, not proof. The network sensor and offline scans are the closest thing to ground truth.
- **Malwarebytes (which you own)** is a fine on-demand second-opinion scanner and its real-time/exploit protection is useful on the *clean* rebuild — but on the compromised host a "no threats" result means little. Don't rely on it as your sole detection layer; it is not an EDR and not out-of-band.

- **Fing (which you own)** is a network *discovery/inventory* tool (device list, open-port checks, new-device alerts) — useful for spotting unexpected devices and exposed ports, but it is not packet inspection or IDS and won't see C2 in encrypted flows. Use it for inventory, not as your monitoring backbone; the Suricata/Zeek sensor is the real monitor.
- **Port mirroring caveats:** the AX3000T allows only one monitor port; mirroring the aggregate `br-lan` or Wi-Fi (rather than a physical switch port) falls back to software and will load the router's CPU and cap throughput. The hardware `skip_sw` mirror of a switch port is the efficient path. The UCI/LuCI port-mirror integration is still an unmerged proposal — use the `tc` script.
- **Pricing/availability:** EDR prices cited are US list and per-endpoint/year; in Brazil (Brasília), expect currency and reseller markups and verify Huntress availability via a local MSP. Free/open-source tools (the bulk of this stack) have no such concern.
- **Cloud sandbox privacy:** files uploaded to VirusTotal/Any.Run/Hybrid Analysis free/public tiers are shared with the community — never upload confidential documents; use local CAPE/VM detonation for sensitive files. `G2`
- **Speculative/vendor-claim items flagged:** "built-in Sysmon" in Windows 11 is newly rolled out and disabled by default; Huntress's 8-minute MTTR and <1% false-positive figures are vendor-published (user-validated but not independently audited); AX3000T-specific mirroring is inferred from the shared MT7531 driver and confirmed reports on MT7530/MT7531-class hardware rather than a direct AX3000T benchmark.